

EPICODE — Institute of Technology

YARA Malware Hunting

Creazione di Regole YARA e Scansione Forense di un File System Compromesso

Scrittura di regole YARA personalizzate per rilevamento di pattern testuali e firme binarie, scansione ricorsiva dell'immagine forense Flare_Incident_Drive e identificazione del file malevolo updater_service.exe

Studente	Mauro Picca
Data	3 Giugno 2026
Corso	EPICODE — Cybersecurity & Ethical Hacking
Modulo	S9 L3 — YARA Malware Hunting
Ambiente	FlareVM (VirtualBox) — YARA preinstallato

Attività svolta esclusivamente a fini didattici in ambiente di laboratorio controllato

Cybersecurity & Ethical Hacking | EPICODE

Indice

1. Introduzione — Cos'è YARA	3
Parte 1 — Verifica di una Regola YARA	4
2. Preparazione dell'Ambiente e Regola Base	4
3. Esecuzione e Verifica	5
Parte 2 — Malware Hunting su Immagine Forense	6
4. Creazione della Regola di Hunting	6
5. Scansione Ricorsiva della Directory Forense	6
6. Risultati e Analisi	7
7. Conclusioni	8

1. Introduzione — Cos'è YARA

L'obiettivo dell'attività è stato apprendere il funzionamento di YARA, uno degli strumenti più diffusi in ambito Cyber Security per l'identificazione di malware, indicatori di compromissione (IOC) e artefatti sospetti all'interno di file system e immagini forensi.

YARA (Yet Another Ridiculous Acronym) è un tool open-source sviluppato da VirusTotal che permette di scrivere regole descrittive per classificare e identificare file. Una regola YARA è composta da tre elementi fondamentali:

Elemento	Descrizione	Esempio
rule	Nome identificativo della regola	rule Rileva_Finto_Malware { ... }
strings	Pattern da ricercare — stringhe testuali o firme binarie esadecimali	\$stringa = "Connessione_C2" ascii wide nocase
condition	Logica booleana che definisce quando la regola fa match	\$stringa or \$firma_binaria

Le regole YARA possono ricercare sia pattern testuali (con modificatori ascii, wide, nocase) sia firme binarie in formato esadecimale. Questo le rende versatili per identificare malware noti, varianti con offuscamento parziale e artefatti specifici di un'intrusione.

💡 YARA è lo standard de facto per la condivisione di firme di malware nella community di threat intelligence. Piattaforme come VirusTotal, Tria.ge e strumenti EDR integrano regole YARA per il rilevamento proattivo. Il repository pubblico YARA-Rules su GitHub contiene migliaia di regole pronte all'uso.

L'esercitazione è stata suddivisa in due parti:

Parte 1 — creazione e verifica di una regola YARA personalizzata su un file di test

Parte 2 — malware hunting mediante scansione ricorsiva di un'immagine forense simulata

⚠️ L'ambiente di laboratorio utilizzato è FlareVM, con YARA preinstallato. Tutte le attività sono state svolte in ambiente isolato a fini esclusivamente didattici.

Parte 1 — Verifica di una Regola YARA

2. Preparazione dell'Ambiente e Regola Base

2.1 Creazione del File di Test

Per verificare il funzionamento di una regola YARA è stato creato un file di testo denominato config.txt contenente la stringa IOC simulata:

```
Connessione_C2_Rilevata
```

La stringa scelta simula un indicatore tipico che potrebbe essere presente in un malware reale — ad esempio la firma di un canale di comunicazione verso un server C2 (Command & Control).

2.2 Scrittura della Regola YARA

È stata creata la regola YARA denominata mia_regola.yar con il seguente contenuto:

```
rule Rileva_Finto_Malware {
  strings:
    $stringa_segreta = "Connessione_C2_Rilevata" ascii wide nocase
  condition:
    $stringa_segreta
}
```

Analisi dei componenti della regola:

Componente	Valore	Significato
Nome regola	Rileva_Finto_Malware	Identificatore univoco della regola — visibile nell'output del match
\$stringa_segreta	"Connessione_C2_Rilevata"	Pattern testuale da ricercare nel file
ascii	Modificatore	Ricerca la stringa in encoding ASCII (8 bit per carattere)
wide	Modificatore	Ricerca anche in encoding UTF-16 (tipico di stringhe Windows)
nocase	Modificatore	Rende la ricerca case-insensitive — trova anche CONNESSIONE_C2_RILEVATA
condition	\$stringa_segreta	La regola fa match se la stringa è presente almeno una volta nel file

3. Esecuzione e Verifica

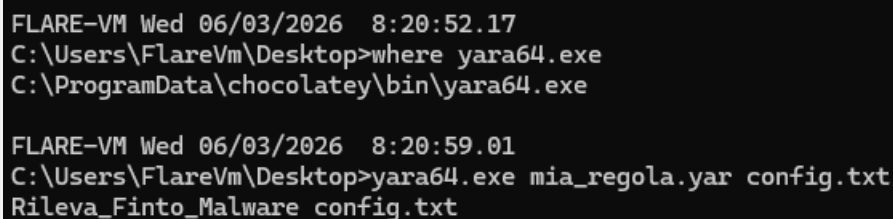
La verifica è stata effettuata tramite il comando:

```
yara64.exe mia_regola.yar config.txt
```

L'output restituito dal programma:

```
Rileva_Finto_Malware config.txt
```

L'output conferma che la regola ha trovato un match: il nome della regola (Rileva_Finto_Malware) è seguito dal percorso del file in cui è stato trovato il pattern (config.txt). Questo è il formato standard dell'output YARA: ogni riga rappresenta un match, con nome regola e file analizzato.



```
FLARE-VM Wed 06/03/2026 8:20:52.17
C:\Users\FlareVm\Desktop>where yara64.exe
C:\ProgramData\chocolatey\bin\yara64.exe

FLARE-VM Wed 06/03/2026 8:20:59.01
C:\Users\FlareVm\Desktop>yara64.exe mia_regola.yar config.txt
Rileva_Finto_Malware config.txt
```

Figura 1 – Esecuzione di yara64.exe con mia_regola.yar su config.txt: match confermato con output Rileva_Finto_Malware.

- ☒ La regola YARA ha identificato correttamente la stringa IOC nel file di test. La prima fase ha confermato il corretto funzionamento dello strumento.

Parte 2 — Malware Hunting su Immagine Forense

4. Creazione della Regola di Hunting

Per la fase di malware hunting è stata scritta una regola più articolata, denominata caccia_malware.yar, che combina due tipi di indicatori:

```
rule Caccia_Malware {
    strings:
    $apt_string = "AntiAV_Bypass_2026" ascii wide nocase
    $inject_code = { E2 9A 12 FF }
    condition:
    $apt_string or $inject_code
}
```

La regola ricerca due indicatori distinti in alternativa (condizione or):

Indicatore	Tipo	Descrizione
\$apt_string — "AntiAV_Bypass_2026"	Stringa testuale	Stringa associata a tecniche di evasione antivirus — tipica di malware APT che incorporano firme di bypass
\$inject_code — { E2 9A 12 FF }	Firma binaria esadecimale	Sequenza di byte caratteristica di un payload di code injection — ricercata nel contenuto binario del file



La condizione or rende la regola più permissiva: basta che uno dei due indicatori sia presente per generare un match. Nelle regole di production si usa spesso una combinazione di and/or con soglie di confidenza (es. 2 of them) per ridurre i falsi positivi.

5. Scansione Ricorsiva della Directory Forense

È stato scaricato ed estratto il dataset fornito dal docente — Flare_Incident_Drive — contenente una simulazione di file system Windows compromesso con la struttura tipica di una partizione di sistema.

La scansione è stata eseguita con il seguente comando:

```
yara64.exe -r caccia_malware.yar C:\Users\FlareVm\Downloads\Flare_Incident_Drive
```

Analisi dei parametri del comando:

Parametro	Significato
yara64.exe	Versione a 64 bit di YARA per Windows — inclusa in FlareVM
-r	Modalità ricorsiva — scansiona tutte le sottocartelle della directory specificata
caccia_malware.yar	File contenente la regola YARA da applicare
C:\...\Flare_Incident_Drive	Directory radice dell'immagine forense da scansionare

La scansione ricorsiva con -r permette di analizzare in un singolo comando l'intera struttura di directory dell'immagine forense, includendo System32, AppData, Temp e tutte le sottocartelle — esattamente come farebbe un analista forense che esamina un disco compromesso.

6. Risultati e Analisi

La regola YARA ha identificato una corrispondenza nel seguente file:

```
C:\Users\FlareVm\Downloads\Flare_Incident_Drive\Windows\System32\drivers\updater_service.exe
```

Il file è stato segnalato come potenzialmente malevolo in quanto contiene almeno uno degli indicatori definiti nella regola caccia_malware.yar.

```
FLARE-VM Wed 06/03/2026 8:48:12.81
C:\Users\FlareVm\Desktop>yara64.exe -r caccia_malware.yar C:\Users\FlareVm\Downloads\Flare_Incident_Drive
Caccia_Malware C:\Users\FlareVm\Downloads\Flare_Incident_Drive\Windows\System32\drivers\updater_service.exe
```

Figura 2 – Output della scansione YARA ricorsiva: match su updater_service.exe in Windows\System32\drivers\.

Analisi del file trovato:

Attributo	Valore	Significato
Percorso	Windows\System32\drivers\	Directory tipicamente riservata ai driver di sistema — la presenza di un .exe è anomala
Nome file	updater_service.exe	Nome che cerca di mimetizzarsi come servizio di aggiornamento legittimo
Estensione	.exe in /drivers/	I file nella cartella drivers dovrebbero essere .sys o .dll — un .exe è un red flag
Indicatore	\$apt_string o \$inject_code	Contiene la stringa AntiAV_Bypass_2026 o la firma binaria E2 9A 12 FF

La posizione del file è particolarmente sospetta: la directory Windows\System32\drivers\ è normalmente riservata ai driver hardware di sistema (.sys) e non contiene eseguibili (.exe). Questo è un classico tentativo di mascheramento — il malware si posiziona in una directory di sistema per sfuggire a un'analisi superficiale.

🔍 Il nome updater_service.exe è un esempio di living-off-the-land naming: il malware usa nomi che imitano servizi Windows legittimi (Windows Update, servizi di manutenzione) per non destare sospetti. In un'analisi forense reale, qualsiasi .exe in System32\drivers\ va investigato immediatamente.

7. Conclusioni

L'esercitazione ha permesso di comprendere il funzionamento delle regole YARA e il loro impiego pratico nelle attività di malware hunting e digital forensics.

Fase	Attività	Risultato
Parte 1 — Regola base	Scrittura regola con stringa ASCII/wide/nocase Scansione di config.txt	☑ Match confermato — Rileva_Finto_Malware config.txt
Parte 2 — Hunting	Regola con stringa + firma binaria esadecimale Scansione ricorsiva -r su Flare_Incident_Drive	☑ updater_service.exe identificato in System32\drivers\

Le due fasi hanno dimostrato le principali capacità di YARA: nella Parte 1 la ricerca di pattern testuali con modificatori per gestire encoding e case sensitivity; nella Parte 2 la combinazione di stringa testuale e firma binaria in una condizione or, applicata a una scansione ricorsiva su larga scala.

YARA è uno strumento fondamentale per i team Blue Team, SOC e Digital Forensics, utilizzato per:

- automatizzare la ricerca di malware su grandi volumi di file
- identificare IOC noti e varianti di famiglie malware note
- effettuare triage rapido durante un Incident Response
- condividere firme di minacce nella community di threat intelligence

Lesson Learned

- I modificatori `ascii`, `wide` e `nocase` sono essenziali per regole robuste: i malware moderni usano spesso stringhe in UTF-16 (`wide`) o offuscate con capitalizzazione variabile. Una regola senza questi modificatori può mancare il match su varianti dello stesso malware.
- La posizione di un file è un IOC tanto quanto il suo contenuto: un `.exe` in `Windows\System32\drivers\` è anomalo per definizione. L'analisi del percorso completo — non solo del nome — è parte integrante di qualsiasi indagine forense.
- YARA scala su grandi quantità di dati: la stessa regola può essere applicata a un singolo file, a un'intera directory o a un'immagine forense da centinaia di GB con un solo comando. Questo la rende indispensabile nelle operazioni di threat hunting su infrastrutture enterprise.

- ☒ Tutti gli obiettivi del laboratorio sono stati raggiunti. Le regole YARA hanno identificato correttamente i pattern definiti — sia nella verifica base che nella scansione forense dell'immagine `Flare_Incident_Drive`.

Fine Relazione — YARA Malware Hunting | Mauro Picca | S9 L3 | 3 Giugno 2026